

# Digerati Experts

## Ultimate Cybersecurity Risk Assessment (CSRA) Service Agreement (Statement of Work)

Issued under the Master Services Agreement (MSA)

### SOW Summary / Order Form

|                                    |                                                           |
|------------------------------------|-----------------------------------------------------------|
| Client Legal Name                  | [FILL]                                                    |
| Client Address                     | [FILL]                                                    |
| Primary Contact (Name/Email/Phone) | [FILL]                                                    |
| Assessment Environment             | On-Prem / Cloud / Hybrid [FILL]                           |
| Primary Platforms / Apps           | Microsoft 365 / Google / Zoho / Other [FILL]              |
| Locations / Sites Included         | [FILL]                                                    |
| Approx. Users                      | [FILL]                                                    |
| Approx. Endpoints / Servers        | [FILL]                                                    |
| Assessment Window (Start - End)    | [FILL]                                                    |
| Executive Interview Participants   | [FILL]                                                    |
| Fixed Fee (if applicable)          | \$(FILL)                                                  |
| Optional TechTime / Project Hours  | [FILL] hours                                              |
| Billing Schedule                   | Per MSA (e.g., 100% upfront / Net 15 / Milestones) [FILL] |
| Effective Date                     | [FILL]                                                    |

This Statement of Work ("SOW") is governed by the Master Services Agreement ("MSA") between Digerati Experts, LLC ("Service Provider") and Client ("Client"). If there is a conflict between this SOW and the MSA, the order of precedence defined in the MSA will apply.

Incorporated Documents. This SOW incorporates by reference the MSA and any applicable Service Level Agreement (SLA), Acceptable Use Policy (AUP), and Data Processing Addendum (DPA) in effect between the parties, plus any executed Change Orders.

## 1. Service Overview

The Ultimate Cybersecurity Risk Assessment (CSRA) is a three-step assessment designed to identify security gaps, validate risk with evidence, and deliver clear recommendations that enable fast executive decision-making. The objective is to help Client understand its current cybersecurity posture and select a practical, prioritized path to reduce business risk.

## 2. Objectives

**The CSRA is designed to:**

- Understand how the business operates and what the executive team values and prioritizes.
- Identify and validate cybersecurity gaps using interviews, technical scanning, and targeted testing.
- Deliver an executive-ready report with observations, findings, and prioritized recommendations.

## 3. Scope of Work

The CSRA is delivered using the following three-step model:

### 3.1 Step 1 - Understand the Business (Executive Discovery)

**Activities may include:**

- Individual interviews with key executives and/or department leads to understand business goals, risk tolerance, and current technology approach.
- Identification of critical business processes, crown-jewel systems, and key compliance or contractual requirements.
- Documentation of business drivers and constraints that shape realistic security decisions.

**Sample interview questions (non-exhaustive):**

- How do you currently manage IT systems and security?
- What are your primary goals over the next 3 years for growth and revenue?
- What role does cybersecurity play in your overall strategy?

### 3.2 Step 2 - Prove Security Gaps Exist (Technical Validation)

Technical activities are selected to match the environment and the agreed assessment window.

**Activities may include:**

- Network and asset discovery, including deep scans of endpoints, servers, storage, and network devices within agreed ranges.
- Configuration and exposure review for identity, email, and cloud services (e.g., suspicious/unauthorized login activity where logs are available).

- Sensitive data discovery for regulated or business-sensitive data (e.g., PII/PHI) on agreed systems.
- Security awareness validation such as phishing simulations (if authorized in writing) and review of related policies and controls.
- Credential exposure checks, including scans for weak or exposed credentials in approved locations and dark web exposure checks for compromised credentials.

All testing is performed in a controlled manner intended to minimize disruption. Activities that could materially increase operational risk (e.g., exploit testing, denial-of-service, red team operations) are out of scope unless explicitly authorized via Change Order.

### 3.3 Step 3 - Observations, Findings, and Recommendations (Executive Reporting)

**Service Provider will:**

- Summarize observations (facts) collected from interviews and technical validation.
- Interpret observations into findings that explain business impact and likelihood.
- Provide prioritized recommendations with practical remediation options and sequencing.
- Deliver an executive briefing to simplify decision-making and answer the core question: how does Client want to manage risk?

## 4. Deliverables

Deliverables may be adjusted based on scope agreed in the SOW Summary / Order Form.

Standard deliverables include:

- CSRA Report (PDF): Executive summary, scope, methodology, observations, findings, risk rating, and prioritized recommendations.
- Risk Register: List of identified risks/vulnerabilities with severity, impacted systems, and remediation guidance.
- Evidence Appendix (as appropriate): Screenshots, scan summaries, and supporting data suitable for IT validation (sanitized where needed).
- Executive Briefing: Live presentation (remote or onsite as agreed) summarizing key findings, recommended next steps, and options.

## 5. Timeline and Milestones

The CSRA is typically completed within the agreed assessment window, subject to timely access and scheduling. A common cadence is:

- Week 1: Kickoff and executive interviews (Step 1).
- Week 1-2: Technical validation and data collection (Step 2).
- Week 2-3: Analysis, report drafting, and internal quality review.

- Week 3-4: Final report delivery and executive briefing (Step 3).

Final dates are defined in the SOW Summary / Order Form.

## 6. Pricing and Payment Terms

Fees are defined in the SOW Summary / Order Form. Unless otherwise stated, invoices and payment terms follow the MSA.

**Common pricing structures include:**

- Fixed fee for the CSRA engagement, scoped by user count, asset count, and environment complexity.
- Optional TechTime / project hours for additional investigation, workshops, or out-of-scope support.

## 7. Assumptions and Client Responsibilities

Client will provide the following to enable delivery of the CSRA:

- Timely scheduling access to executives and key stakeholders for interviews.
- Written authorization for scanning/testing and approval of target ranges, domains, and systems.
- Administrative or read-only access to agreed systems (e.g., identity, email, cloud logging) where necessary for evidence collection.
- An internal point of contact to coordinate access, change windows, and communications.
- Accurate asset inventories where available (or agreement that discovery will be used as the baseline).

Delays caused by missing access, incomplete information, or late approvals may affect the timeline.

## 8. Out of Scope

Unless explicitly included in the SOW Summary / Order Form or a Change Order, the following are out of scope:

- Penetration testing involving exploitation of vulnerabilities, red team operations, or adversary emulation.
- Denial-of-service testing, destructive testing, or any activity intended to degrade availability.
- Remediation implementation (patching, configuration changes, tool deployment), except for minor fixes explicitly approved during the engagement.
- Full compliance audits (e.g., SOC 2, ISO 27001) or legal/regulatory determinations.
- Third-party vendor application security assessments beyond basic exposure review.

## 9. Limitations and Authorized Testing

The CSRA is a point-in-time assessment based on the information, access, and systems made available during the assessment window. While Service Provider will use commercially reasonable efforts to identify meaningful risks, no assessment can guarantee that all security issues, threats, or vulnerabilities will be discovered.

Client must provide written authorization for the agreed scanning and testing activities and confirm the approved targets (e.g., IP ranges, domains, systems). Service Provider will limit activities to the approved targets and methods. If Client requests a pause or stop, Service Provider will comply as soon as practical.

## 10. Change Management

Any change to scope, targets, testing methods, deliverables, timeline, or fees must be documented and approved in a written Change Order signed by both parties. Additional fees may apply.

## 11. Acceptance Criteria

Deliverables are considered accepted when:

- Service Provider delivers the final CSRA Report and Risk Register to Client's designated contact, and
- The executive briefing is delivered (or scheduled and offered in good faith), and
- Client does not notify Service Provider of material nonconformance within five (5) business days of delivery (or within the acceptance window defined in the MSA, if different).

### Guarantees and Service Credits

If Client selected any optional guarantees on the Order Form, those guarantees apply to Covered Services under this SOW only as described in Exhibit G of the MSA and the Service Credit Schedule in Exhibit A (SLA).

## 12. Signatures

By signing below, the parties agree to this SOW under the MSA.

|                  |                       |
|------------------|-----------------------|
| Client           | Digerati Experts, LLC |
| Name: [FILL]     | Name: Joseph Petro    |
| Title: [FILL]    | Title: Owner          |
| Signature: _____ | Signature: _____      |
| Date: [FILL]     | Date: [FILL]          |